Chapter 08

Advanced Security and Compliance

Episode 8.01

Episode title: **Account Hardening**

Objective: 3.4

Account Hardening Overview

Account hardening goals

Password and expiration policies

Restricted shells

Linux+ XK0-006 Domain 3.4

Password Policy Enforcement with PAM

PAM framework

- pam_pwquality
- pam_faillock

pam_tally2 and Account Lockout (legacy)

pam_tally2

Legacy account lockout module

Tracks failed login attempts

Superseded by pam_faillock

Still listed in exam objectives

Multifactor Authentication

Multifactor authentication (MFA)

Something you know, have, or are

Common Linux MFA integrations

Exam focus: risk reduction

Password Breach Detection & Monitoring

Checking passwords against breach lists

Prevents reuse of compromised credentials

Often integrated with PAM

Part of modern account hardening

Password Aging with Expiration Controls

/etc/shadow field breakdown
chage usage and flags (-l -M -m -W -E -I)

Password vs account expiration

Restricted Shells and Account Limitation

/bin/false, /sbin/nologin, rbash, forced-command in authorized_keys

chroot, internal-sftp, and related SSH configurations

Service account best practices and ownership

Account Hardening Utilities (DEMO)

Enforcing password aging and expiration (chage)

Distinguishing password expiration vs account expiration

Applying PAM-based password quality and lockout controls

Restricting account access using non-interactive shells

Identifying service vs human account best practices

Episode 8.02

Episode title: **Cryptography Concepts**

Objective: 3.5

Cryptography Concepts Overview

Purpose of cryptography: confidentiality, integrity, authenticity

Where Linux uses cryptography (at rest, in transit, for authentication)

Linux+ XK0-006 Domain 3.5

Encryption Concepts: Symmetric & Asymmetric

Symmetric encryption: keys, performance, LUKS/dm-crypt

Asymmetric encryption: key pairs, digital signatures, SSH/TLS use

Key management, entropy, and operational considerations

Hashing & Data Integrity

Hash functions: one-way, fixed-length output

Common algorithms: SHA-1, SHA-256, SHA-512, and collision concerns

Uses: password storage, integrity checks, digital signatures

Modern Password Hashing – Argon2

Argon2 password hashing algorithm

Memory-hard design

Resistant to GPU and ASIC attacks

Recommended for password storage

TLS, Certificates, and PKI

TLS handshake basics and cipher suites

Certificates, CAs, trust chains, CRLs/OCSP

Managing certificates on Linux: stores, paths, and OpenSSL commands

Certificate Authorities & Trust Models

Trusted root certificates

No-cost certificate authorities

Commercial certificate authorities

Trust chains and validation

Avoiding Self-Signed Certificates

Self-signed certificates lack external trust

Acceptable for testing only

Use trusted CAs in production

Exam best practice

Secure Data in Transit – Exam Tools

OpenSSL – Common TLS toolkit

LibreSSL – OpenSSL alternative

WireGuard – Modern VPN protocol

Protecting data in transit

TLS Versions & Weakened Algorithm Removal

TLS protocol versions

Deprecation of SSL and early TLS

Removal of weak ciphers and hashes

Security and compliance requirement

Cryptography Tools & Verification (DEMO)

Hashing vs encryption vs signing

Integrity verification with checksums

Encryption and signing with GPG

Certificate inspection and validation

Exam Tips & Summary

Match cryptographic goals to tools

Understand practical trade-offs and operational considerations XK0-006 focus areas: hashing vs encryption, TLS basics, certificate management

Operational Best Practices (Cryptography)

Protect & Manage Keys: Secure private keys; backup key material.

Use Strong Algorithms: Prefer SHA-256/512; remove weak ciphers.

Validate Often: Inspect keys, certs, checksums.

Layered Security: Encryption doesn't replace ACLs or logging.

Episode 8.03

Episode title: **File Integrity & Detection**

Objective: 3.6

File Integrity Overview

Purpose of file integrity monitoring

Threats: malware, rootkits, unauthorized change

Linux+ XK0-006 Domain 3.6

Detection, Response, & Indicators of Compromise

Anti-malware detection

Indicators of compromise (IOC)

Alerting and response workflows

Early threat detection

File Integrity Monitoring Concepts

Baselines and cryptographic checksums

Change detection vs change authorization

Scheduling and alerting

AIDE: Advanced Intrusion Detection Environment

AIDE purpose and architecture

Databases, rules, and policies

Baseline creation and updates

Rootkit Detection & Package Verification

rkhunter purpose and limitations

Package verification (rpm, dpkg)

When to use each approach

Integrity & Detection Tools (DEMO)

- File integrity monitoring
- Baseline creation and comparison
- Rootkit detection
- Package integrity verification

Episode 8.04

Episode title: **Compliance Standards**

Objective: 3.6

Compliance Standards Overview

Purpose of compliance frameworks

Security baselines and auditing

Linux+ XK0-006 Domain 3.6

Security Banners & Legal Notices Files

/etc/issue

/etc/issue.net

/etc/motd

Legal notice and deterrence

Vulnerability Scanning & Risk Scoring

Common Vulnerabilities and Exposures (CVE)

Common Vulnerability Scoring System (CVSS)

Backporting security patches

Misconfigurations and exposure risk

CIS Benchmarks

Center for Internet Security (CIS)

Prescriptive benchmarks

Scoring, remediation, and profiles

OpenSCAP & Automated Compliance

SCAP overview

OpenSCAP tools and content

Scanning, reporting, remediation

Auditing, Evidence & Continuous Compliance

Auditing vs logging

Evidence collection

Continuous compliance

Compliance Assessment Tools (DEMO)

Compliance vs hardening

Baseline assessment and evidence collection

Automated compliance scanning

Interpreting findings (not enforcing fixes)

Episode 8.05

Episode title: **Secure Data & Supply Chain**

Objective: 3.5

Secure Data & Supply Chain Overview

Protecting data at rest and in motion

Secure deletion and lifecycle management

Software trust and supply chain security

Encrypting Data at Rest

Filesystem and block-device encryption

LUKS and dm-crypt concepts

Key management and operational considerations

Secure Data Destruction

Data remanence and risk
Secure deletion tools (shred, wipe)

When encryption simplifies destruction

Secure Data Destruction Methods

shred – Overwrite files

badblocks –w

Destructive disk test

dd if=/dev/urandom

Random overwrite

Cryptographic destruction

Software Trust & Supply Chain Security

Package signing and repositories
GPG keys and trust chains

Risks of untrusted software sources

Secure Data & Supply Chain (DEMO)

Data encryption and secure storage

Secure deletion and data destruction concepts

Software authenticity and integrity verification

Trust validation in the Linux software supply chain